

Project: Information Security Management System (ISMS) Baseline

Organization: Apex Manufacturing

Assessor: Ahmad Sofian Bin Shaharudin

Framework: ISO 27001:2022

Date: April 2026

1. Executive Summary

Apex Manufacturing is currently in the “Developing” stage of security maturity. While physical security control is robust, there is significant risk regarding the convergence of IT and OT networks. Currently, the organization is **28% compliant** with the selected ISO 27001 baseline. Immediate focus is required on network segmentation and identity management to prevent production downtime.

2. Scope & Goals

- **Scope:** The Corporate Management Network (IT) and The Production Flow (OT).
- **Goal:** To establish a security baseline that protects intellectual property and ensures 24/7 manufacturing availability.

3. Maturity Status

- Total Controls Assessed: 18
- Compliant: 6
- Partially Compliant: 5
- Non-Compliant: 7

Gap 1: Lack of Network Segmentation (A.8.20)

- **The Problem:** The network is “flat”. Corporate office laptops can communicate directly with the Programmable Logic Controller (PLCs).
- **The Risk:** A single phishing email in the HR department could allow ransomware to spread and shut down the entire assembly line.
- **Remediation:** Implement Purdue Model architecture using industrial firewalls to create a “buffer zone” (DMZ) between the IT and OT environments.

Gap 2: Weak Authentication in Production (A.8.5)

- **The Problem:** Factory workstation (HMIs) uses shared passwords like “Operator1” and no MFA is present.
- **The Risk:** An unauthorized person or a disgruntled employee could make unauthorized changes to machine logic without any audit trail.
- **Remediation:** Transition to individual user accounts linked to Active Directory. Deploy hardware security keys for operators

Gap3: Shadow OT Asset Inventory (A.5.9)

- **The Problem:** There is no automated list of what is actually plugged into the factory network.
- **The Risk:** We cannot protect or patch what we don’t know exist. Unknown devices are “backdoors” for attackers, potential to zero-day attacks.
- **Remediation:** Deploy a passive network monitoring tool to discover and catalog all OT assets without interrupting factory operations.